

# 对不安全文件上传系统的一些漏洞复现

---

## 路径穿越漏洞

漏洞成因(大概)

示例

## 任意文件上传漏洞

漏洞成因

示例

## 任意文件读取漏洞

漏洞成因

示例

## sql注入

漏洞成因

示例

## 路径穿越漏洞

### 漏洞成因(大概)

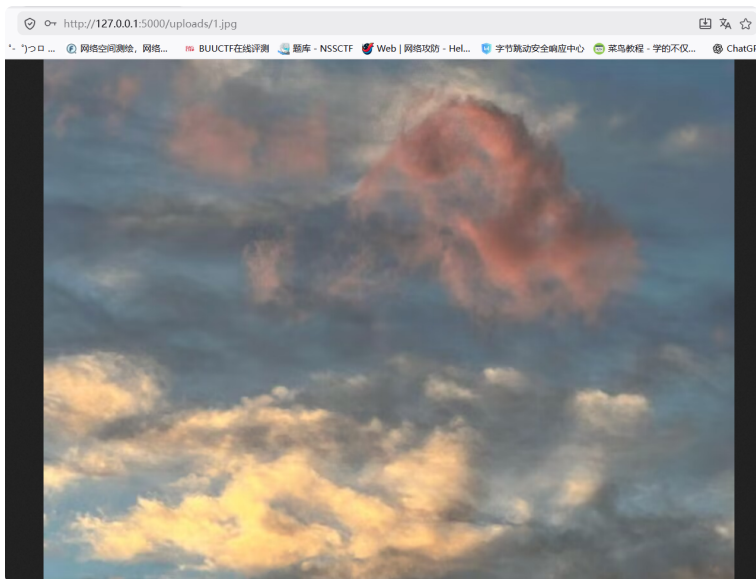
```
@app.route('/uploads/<path:filename>')
def uploads(filename):
    try:
        file_path = os.path.join(
            app.config['UPLOAD_FOLDER'],
            filename
        )
```

这里的目录拼接，程序未对../进行过滤，后续操作系统会解析../返回上一级目录。

### 示例

我们在根目录下我们有一个test.txt

我们成功登陆后，随便上传一张图片，上传成功后，点击查看图片，进入uploads路由



假如我们知道在这个项目的根目录下有一个test.txt。我们想看其内容。直接访问/test.txt不行，一般来说我们只能直接看到静态目录(例如static)下的文件

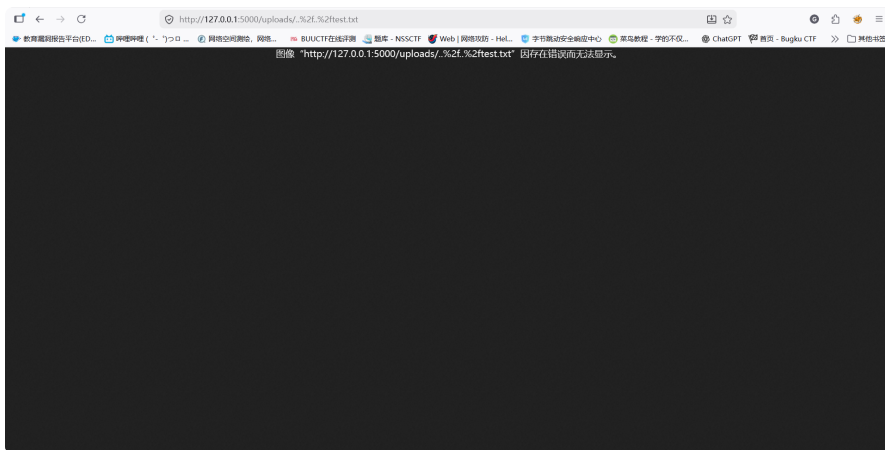


## Not Found

The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.

浏览器向服务器发送数据先会对url进行规范化，检测到../会进行折叠，然后将url传给服务器，服务器对url进行一次解码。所以我们直接用<http://127.0.0.1:5000/uploads/../../test.txt>，也会被折叠成<http://127.0.0.1:5000/test.txt>。像上图一样Not Found。

但是我们可以用<http://127.0.0.1:5000/uploads/..%2f..%2ftest.txt>。%2f是/的url编码。在浏览器的url规范化中由于是..%2f被当作是正常字符串不会对url进行折叠。然后url被传给服务器解码，%2f解码成/，然后进行路径跳转。（这里看不到文件内容因为是将该文件当作图片类型文件处理展示的）



我们抓包可以看到文件的文本信息，成功



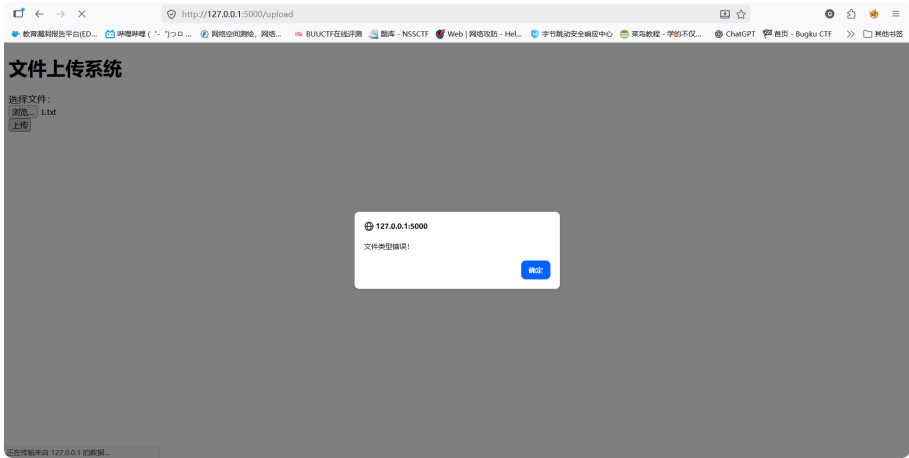
# 任意文件上传漏洞

## 漏洞成因

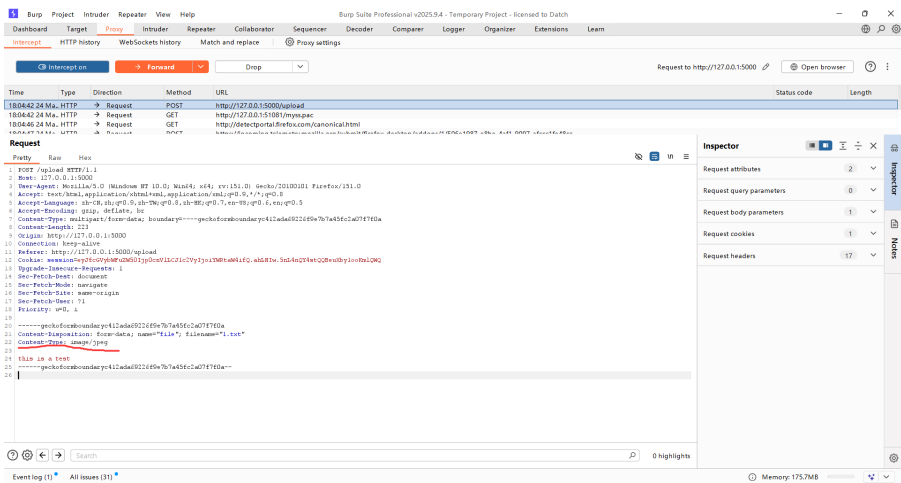
文件类型校验不严格，只有简单的file.content\_type.startswith('image/')

## 示例

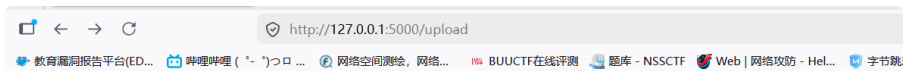
该系统只允许上传图片类型文件。我们上传txt文件，提示文件类型错误



我们抓包然后修改Content-Type,从text/plain改成image/jpeg



上传成功



## 文件上传系统

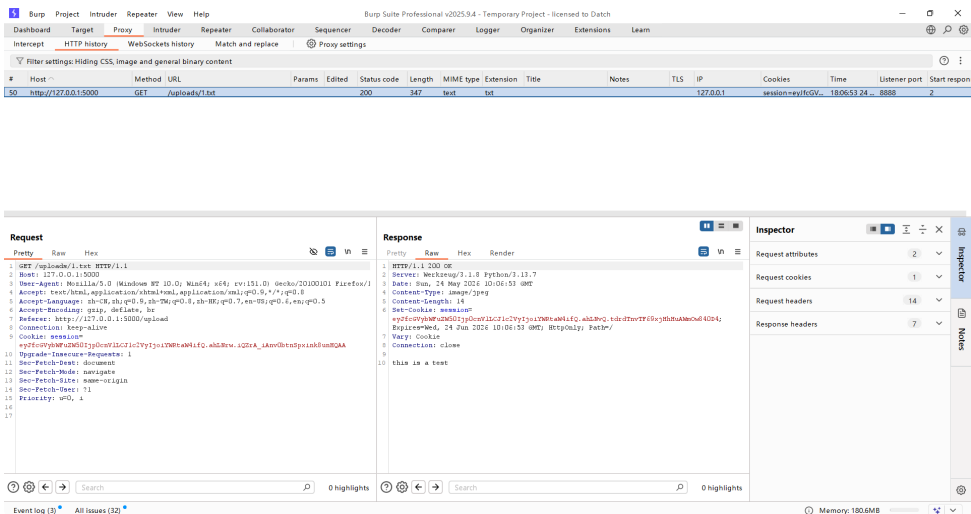
文件上传成功! 存在: /uploads/1.txt

[查看图片](#)

选择文件:

未选择文件。

点击查看图片，同样无法显示然后重发抓包查看，可以看到1.txt里的内容



由于该系统不会解析php文件，所以无法展示图片马上传和蚁剑链接getshell，但是木马文件也可以基于此上传，危害极大。

# 任意文件读取漏洞

## 漏洞成因

该漏洞其实是基于路径穿越漏洞的。

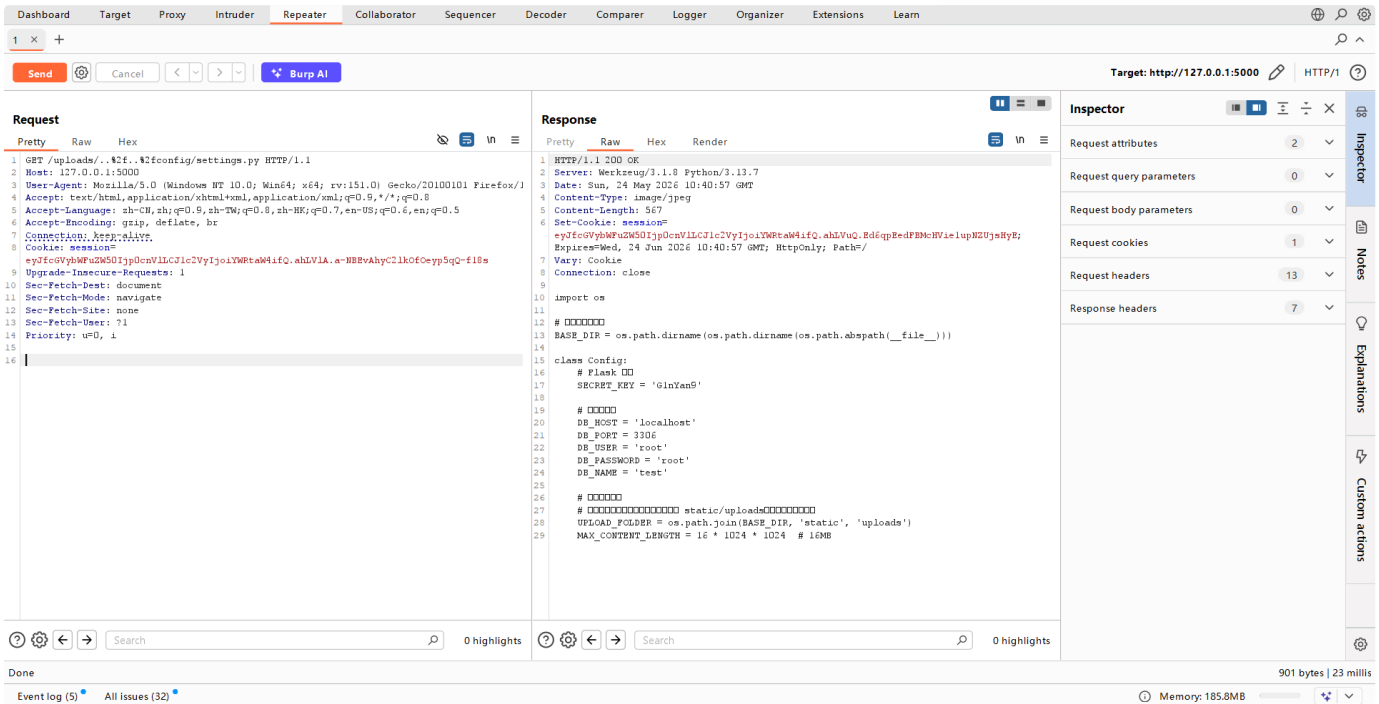
## 示例

我们在config目录下有settings.py配置文件，直接访问/config/settings.py不行，NotFound

我们到uploads路由下，构造url

<http://127.0.0.1:5000/uploads/..%2f..%2fconfig/settings.py>

抓包查看，成功看到文件内容



# sql注入

## 漏洞成因

字符串拼接

## 示例

在登陆界面可以实现sql注入

127.0.0.1:5000/login

教育漏洞报告平台(ED... 哔哩哔哩 (゜-゜)つロ... 网络空间测绘, 网络... BUUCTF在线评测 题库 - NSSCTF Web | 网络攻防 - Hel... 字节跳动安全响应中心 菜鸟教程 - 学的不仅... ChatGPT 首页 - Bugku CTF >> 其他书签

# Login

Username:

' or '1'='1'--

Password:

Login

Not registered yet? [Register](#)

127.0.0.1:5000

Login success, redirect to profile page?

确定 取消

正在传输来自 127.0.0.1 的数据...

127.0.0.1 - - [26/May/2026 23:08:17] "GET /logout HTTP/1.1" 302 -

127.0.0.1 - - [26/May/2026 23:08:17] "GET /profile HTTP/1.1" 200 -

127.0.0.1 - - [26/May/2026 23:08:20] "GET /login HTTP/1.1" 200 -

select \* from `unsafe\_table` where `ant` = '' or '1'='1'-- ' and `pwd`='1'

('admin', 'admin')

127.0.0.1 - - [26/May/2026 23:08:27] "POST /login HTTP/1.1" 302 -

127.0.0.1 - - [26/May/2026 23:08:27] "GET /login HTTP/1.1" 200 -

127.0.0.1 - - [26/May/2026 23:08:44] "GET /profile HTTP/1.1" 200 -